PENSE-BÊTE · MÉTHODES ET GOUVERNANCE

Méthodologie EBIOS Risk Manager

03-30 ANSSI - EBIOS Risk Manager Méthodologie d'appréciation des risques — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La démarche combine une approche par conformité et par scénarios à travers 5 ateliers itératifs.
2. Le cycle stratégique revisite l'étude et les scénarios stratégiques tous les 3 ans tandis que le cycle opérationnel est annuel.
3. Le niveau de risque est une mesure de l'importance du risque exprimée par la combinaison de la gravité et de la vraisemblance.

EBIOS Risk Manager

Notion	À retenir
Présentation démarche	Méthode d'**appréciation** et de **traitement** du risque numérique. Boîte à outils **adaptable**. Combine approche par **conformité** et par **scénarios**. 5 ateliers **itératifs**.
Cycles méthode	Deux cycles : **stratégique** (revisite l'étude et scénarios stratégiques, tous les **3 ans**) et **opérationnel** (scénarios opérationnels, incidents, vulnérabilités, base **annuelle**).

Atelier 1 : Cadrage et socle de sécurité

Notion	À retenir
Objectifs et périmètre	Définit le cadre, le périmètre **métier** (missions, valeurs métier) et **technique** (biens supports), les événements redoutés et le socle de sécurité.
Identification des biens supports	Composants du SI (systèmes, réseaux, organisations, locaux) sur lesquels reposent les **valeurs métier** ou les **mesures de sécurité**.
Événements redoutés et gravité	Identifie les événements et impacts (missions, humains, financiers, juridiques, image). Échelle définie avec les métiers, généralement **4 ou 5 niveaux** (de **mineure** à **critique/catastrophique**).
Le socle de sécurité	Référentiels et réglementations applicables. Évalue l'état d'application et les écarts pour traiter les **risques communs** via une approche de **conformité**.

Atelier 2 : Sources de risque

Notion	À retenir
Identification et caractérisation	Identifier les **sources de risque** (ex: **organisations étatiques**, **crime organisé**, **terroristes**, **activistes**, **employés malveillants**) et leurs **objectifs visés** (ex: **espionnage**, **gain lucratif**, **entrave**).
Sélection des couples	Évaluer la **pertinence** des couples (motivation, ressources, activité) pour prioriser. Formalisation dans une **cartographie** (souvent un **radar**).

Atelier 3 : Scénarios stratégiques

Notion	À retenir
Cartographie écosystème	Évaluer la menace des **parties prenantes** (partenaires, fournisseurs, clients, filiales, services connexes) via **dépendance**, **pénétration**, **maturité** et **confiance**.
Scénarios stratégiques	Chemins d'attaque de **haut niveau** exploitant les **vulnérabilités structurelles** et les relations critiques pour atteindre un objectif ; gravité estimée par les **impacts sur les valeurs métier**.
Mesures de sécurité	Réduire la menace (ex: **augmenter confiance**, **diminuer dépendance**). **Zone de danger** : réduire risque ou refuser interaction. **Zone de contrôle** : surveillance particulière.

Scénarios et vraisemblance

Notion	À retenir
Construction scénarios	Graphe d'attaque enchaînant des **actions élémentaires** sur des **biens supports**. Séquence type : **Connaître**, **Rentrer**, **Trouver** et **Exploiter**.
Évaluation vraisemblance	Degré de **faisabilité** ou **probabilité**. Méthodes : **expresse**, **standard** (probabilité de succès des actions) ou **avancée** (succès + **difficulté technique**).

Synthèse du traitement du risque

Notion	À retenir
Synthèse et stratégie	Positionnement des scénarios sur une **cartographie** (**gravité** et **vraisemblance**) et fixation des **seuils d'acceptation** (inacceptable, tolérable sous contrôle ou acceptable).
Plan de traitement	Formalisation des mesures selon la **défense en profondeur** (**gouvernance**, **protection**, **défense**, **résilience**) avec responsable, coût, charge, échéance et difficultés.
Risques résiduels et suivi	Évaluation des risques **subsistant** après mesures et mise en place d'un **cadre de suivi** avec **indicateurs de pilotage** (efficacité et menace).

Pièges et confusions

- ⚠ Confondre les objectifs visés par la source de risque avec la motivation qui la pousse à agir
- ⚠ Croire que l'évaluation de la dangerosité des parties prenantes présuppose une intention malveillante
- ⚠ Oublier que les mesures de sécurité du socle doivent être considérées comme acquises lors de l'élaboration des scénarios
- ⚠ Considérer l'estimation de la vraisemblance comme prédictive au lieu de la considérer comme conditionnelle à la tentative de l'attaquant
- ⚠ Penser qu'une mesure de sécurité réduit le niveau de risque immédiat sans être effectivement mise en œuvre avant la poursuite de l'analyse

Sigles et définitions

Appréciation des risques	Ensemble du processus d'identification, d'analyse et d'estimation des risques (ateliers 2, 3 et 4)
Bien support	Composante du système d'information sur laquelle repose une ou plusieurs valeurs métier
Chemin d'attaque	Suite d'événements distincts que la source de risque devra probablement générer pour atteindre son objectif dans les scénarios stratégiques
Scénario opérationnel	Enchaînement d'actions élémentaires portées sur les biens supports, estimé en termes de vraisemblance
Source de risque	Élément, personne ou organisation susceptible d'engendrer un risque, caractérisée par sa motivation et ses ressources
Valeur métier	Composante importante pour l'organisation dans l'accomplissement de sa mission

Auto-test

1. Combien d'ateliers composent la démarche EBIOS Risk Manager ?
2. Quelle est la fréquence du cycle stratégique ?
3. Quels sont les deux éléments qui composent le niveau de risque ?
4. Sur quoi repose l'estimation de la gravité dans les scénarios stratégiques ?
5. Quelle est la séquence type d'un graphe d'attaque ?

Réponses : **1.** 5 · **2.** Tous les 3 ans · **3.** La gravité et la vraisemblance · **4.** Les impacts sur les valeurs métier · **5.** Connaître, Rentrer, Trouver et Exploiter

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.